

failforward.dev, project handoff summary

Context dump for a local AI assistant picking up this project. Written 2026-07-25. Current version: v1.3.0.

1. What this is

[failforward.dev](#) is Chad Longanecker's developer portfolio and personal brand site. Purpose: attract senior security engineering roles and consulting contracts by publicly documenting engineering failures, automated systems, and AI risk governance work.

Positioning: Security Automation Engineer plus AI risk governance. Proof points used throughout: 15+ years, 250+ environments, 23 countries, DLP, incident response, M&A security integration, Python pipelines. Based in Krakow, Poland. American citizen with Polish permanent residence. Target roles are remote EU/EMEA or hybrid Poland.

2. Tech stack and architecture

Layer	Choice
Framework	Astro 5, static export, no client framework
Content parsing	gray-matter plus zod validation, marked for markdown
Host	GitHub Pages, built by GitHub Actions
Repo	github.com/HuggingBunny/failforward-dev
Registrar and DNS	Porkbun
Admin	Sveltia CMS, git-based, at /admin
Local path	Hermes vault / 06 Career / failforward.dev

There is no server, no database, no runtime backend. Every deploy is: push to `main`, Actions runs the guardrail test then the build, output goes to GitHub Pages.

Note: an earlier iteration targeted Cloudflare Pages. That was replaced with GitHub Pages once Chad confirmed the actual repo. Any Cloudflare references in old notes are stale.

3. The safety guardrail (most important design decision)

`src/lib/vault.ts` ingests markdown and publishes a note **only** if its YAML frontmatter contains the literal boolean `publish: true`. Everything else is excluded and logged: missing key, `publish: "true"` as a string, malformed YAML, no frontmatter, invalid category or severity. It fails closed.

`scripts/test-guardrail.mjs` regression-tests this against six hostile fixture inputs and runs in CI **before** the build, so a broken filter fails the deploy rather than leaking a private note.

Do not weaken this. It is both a safety mechanism and a portfolio talking point.

4. Site structure

/ home: identity, hero, AI Warning Labels showcase, recent incidents

/incidents/ post-mortem gallery with category filters

/incidents/<slug>/ individual post-mortem (from content/incidents/*.md)

/projects/ lab index with honest status badges

/projects/shadow-ai-playbook/ full Shadow AI governance playbook v0.3

/writing/ two LinkedIn series

/writing/<slug>/ individual post pages, hosted locally

/hire full-time and consult paths plus consult intake form

/demos/api-governance.html interactive API governance dashboard prototype

/admin/ git-based CMS

Content sources

Content	Lives in	Edited via
Post-mortems	<code>content/incidents/*.md</code>	admin or markdown files
Projects	<code>src/data/projects.json</code>	admin
Writing series and posts	<code>src/data/writing.json</code>	admin
AI Warning Labels	<code>src/data/labels.json</code>	admin

Page bodies are reusable components in `src/components/pages/`; route files in `src/pages/` are thin wrappers.

5. Featured projects on the site

1. **AI Warning Labels** (flagship): a standardized hazard-communication framework for AI systems adapted from GHS chemical labeling, ISO 7010 signage, and nutrition-facts panels. Interactive showcase on the home page with hazard pictograms, a transparency facts panel, traffic-light rating, deployment risk placards, and certifications. Data-driven from `labels.json`. Separate deploy target reserved: `huggingbunny.dev`.
 2. **Shadow AI and Shadow IT Governance Playbook v0.3**: five-phase operational playbook (Locate, Secure, Manage, Maintain, Respond) plus a triage risk-scoring bridge, anchored to EU AI Act, GDPR, NIST AI RMF, ISO 42001. Published as a working draft with Chad's internal "To add" notes deliberately visible.
 3. **API Governance Dashboard**: interactive prototype with fake data for governing 4,000+ APIs. Three tabs (Registry, Command Center, Security Posture), live search and filters, clickable rows opening a detail drawer, cross-navigation from alerts and posture cards. Originally three side-scrolling static frames; rebuilt as a single clickable app.
 4. **Writing**: two LinkedIn series. Series 02 "The Wrong Hire" (ADHD, misfits, security engineering in the agentic world), post 1 published 2026-04-23, posts 2 through 8 drafted. Series 01 "What Free Services Collect About You", seven parts, unpublished.
-

6. Design system

- Ice blue palette: cold navy-black canvas with a desaturated steel accent (`#6fb3d8` dark, `#1d5a80` light). Chosen deliberately so red, amber, and green stay reserved for severity and hazard semantics rather than branding.
- Light and dark themes, each tuned separately (light is not an inversion). Toggle in nav, respects OS preference, persists in `localStorage`, set before paint to avoid flash.
- Type scale via CSS variables, JetBrains Mono reserved for tags, badges, buttons, telemetry. Inter for body.
- Micro-interactions at 150ms with a `prefers-reduced-motion` guard, visible `focus-visible` outlines.
- Favicon and a 1200x630 OG image for LinkedIn shares.

Hard style rule

No em dashes anywhere. Chad considers them a tell of AI-generated writing and his brand depends on authentic voice. 128 were purged from the codebase; the built output contains zero. Use commas, colons, periods, or semicolons. Use "." for title separators. This applies to all future content.

Other stripped conventions: bracketed section numbers like `[05]` were removed as internal indexing leaking into the UI.

7. Consult intake form

On `/hire`. Fields: name, work email, company, engagement type, problem description, timeline, data sensitivity, budget range EUR, referral. Protections: required-field validation, length caps, hidden honeypot that silently rejects bots.

Two collection modes controlled by one constant (`FORM_ENDPOINT` in `HireBody.astro`):

- Empty string (current): composes a structured email in the visitor's own mail client. No third party involved.
 - Set to a Formspree endpoint: POSTs over HTTPS. Requires updating the privacy note wording for GDPR, since Formspree becomes a data processor.
-

8. Admin CMS

`/admin` runs Sveltia CMS. It reads content directly from the GitHub repo and every Save is a commit that triggers the deploy. Access control is GitHub repo write access; there are no separate CMS accounts. Audit trail is git history.

Four sections, each with field schemas and templates: Incidents (opens with a post-mortem skeleton, `publish: false` by default), Projects page, Writing page, AI Warning Labels. Dropdowns enforce allowed values so the CMS cannot produce content the build would reject.

Not yet configured: login needs a free Cloudflare Worker (`sveltia-cms-auth`) because GitHub Pages cannot hold OAuth secrets. Steps are in MAINTENANCE.md section 7c. Until then `/admin` loads but cannot sign in. The site is unaffected.

9. Documentation in the repo

File	Covers
<code>README.md</code>	overview, layout, commands
<code>DEPLOY.md</code>	GitHub Pages setup, Porkbun DNS records, custom domain, HTTPS
<code>MAINTENANCE.md</code>	day-to-day upkeep, adding content, troubleshooting, safety rules
<code>ADMIN.md</code>	how the CMS works, daily use, modifying sections and templates, security
<code>HANDOFF.md</code>	this file

10. Current state and open items

Build status: passes, 14 pages, guardrail test PASS, no draft leakage, zero em dashes.

Known gaps, in priority order:

1. The four post-mortems are AI-invented, written in Chad's voice from his background but factually fictional. They must be replaced with real incidents before the site is shared widely. This is the only genuine blocker.
2. Admin OAuth worker not deployed, so `/admin` cannot sign in yet.
3. Formspree endpoint not configured, so the intake form uses the mailto fallback.
4. Series 02 posts 2 through 8 have no bodies, showing as UPCOMING cards.
5. LinkedIn post hooks are AI summaries, not the real published lines.
6. The OG image uses DejaVu rather than the site's Inter and JetBrains Mono, since those fonts were unavailable during generation.
7. The Series 01 intro slug is auto-generated and ugly:
`intro-the-trade-you-didn-t-know-you-made`.
8. Chad's Obsidian drafts in `06 Career/LinkedIn Series/` still contain em dashes; the vault was not modified.

Upload steps not yet done: delete the three placeholder files in the repo (`index.html`, `oxide2.html`, `LICENSE`), push the contents, set Pages source to GitHub Actions, add the Porkbun DNS records (four A records to `185.199.108-111.153` on the apex, `www` CNAME to `huggingbunny.github.io`), then enable Enforce HTTPS.

11. Working preferences to carry forward

- Direct, no padding, no affirmations. Bottom line first.
- Break complex work into numbered steps. Surface unfinished work at session start.
- Never recommend Microsoft products; prefer open source or non-Microsoft alternatives.
- Honest status labels over flattering ones; drafts should say draft.
- Never claim a security property the platform does not actually provide. A "CSP enforced" claim was removed from the site footer for exactly this reason, since GitHub Pages cannot set CSP headers.